From PINs to Gestures: Analyzing Knowledge-Based Authentication Schemes for Augmented and Virtual Reality

Naheem Noah and Sanchari Das

Abstract— As Augmented and Virtual Reality (AR/VR) advances, secure and user-friendly authentication becomes vital. We evaluated 17 authentication schemes across gaze, gesture, PIN, spatial, and recognition-based categories using a systematic framework focused on effectiveness, security, and usability. Our analysis revealed varied performance and significant gaps requiring standardized methods. For example, Beat-PIN demonstrated strong security with 140-bit entropy, while RubikAuth achieved high usability with authentication times of 1.69 seconds. Gaze-based methods, though innovative, faced accuracy issues. We also observed a preference for schemes like In-Air Handwriting and Things, which balanced security and ease of use. By extending Bonneau et al.'s framework [5] to develop an AR/VR-specific evaluation model, we identified schemes like RubikAuth and Things as particularly promising for AR/VR. This study highlights the strengths and limitations of current methods and emphasizes the need for cross-modal and context-aware techniques to advance AR/VR authentication.

Index Terms—Knowledge-Based Authentication, Augmented Reality, Virtual Reality, Secure Authentication.

1 Introduction

Authentication in Augmented and Virtual Reality (AR/VR) presents unique challenges and opportunities as traditional methods designed for 2D interfaces may not translate well to the spatial and interactive nature of these technologies [64]. While biometric and token-based authentication has gained traction in recent years [65], knowledge-based authentication remains particularly well-suited for AR/VR environments [45, 55]. This is due to its flexibility, low implementation cost, and ability to leverage the unique spatial and interactive capabilities of AR/VR systems [63, 71]. Knowledge-based methods, such as PINs [9], passwords [7], and graphical authentication [14] schemes, can be adapted to utilize 3D spaces, gesture recognition, and gaze-based interactions, potentially enhancing both security and usability in immersive environments [30, 51].

In AR/VR contexts, authentication serves multiple critical functions: it protects personal and financial information in virtual marketplaces, secures confidential data in enterprise VR collaborations, and protects user identity in social VR platforms [53]. Moreover, effective authentication in AR/VR can enhance user trust, which is essential for the widespread adoption of these technologies [15, 57]. By leveraging the unique affordances of AR/VR, such as spatial awareness and natural gesture interactions, novel authentication methods can potentially offer improved security while maintaining or even enhancing usability compared to traditional approaches [21]. As AR/VR technologies continue to evolve, developing secure and usable authentication methods becomes crucial.

To ensure authentication schemes are secure and usable, it is important to evaluate the effectiveness and user experience [10, 11, 72]. This requires an approach that considers multiple factors, including security, usability, and effectiveness [8, 12, 37]. Traditional metrics such as entropy, authentication time, and error rates provide valuable insights, but they may not capture the full complexity of user interaction in immersive spaces [13]. To address this, researchers have developed more holistic evaluation frameworks for authentication such as the Bonneau et al.'s framework [5] that offers a systematic method for analyzing authentication schemes across 25 criteria in three categories: usability, deployability, and security. This framework, originally designed for web authentication, has been adapted and applied to various contexts, including mobile and AR/VR authentication [50]. By employing comprehensive evaluation methods, researchers can better understand the strengths and weaknesses of AR/VR authentication schemes, aiding the development of more effective, user-friendly solutions. However, holistic frameworks and systematic evaluations for AR/VR authentication remain underexplored. In this study, we evaluate 17 knowledge-based authentication schemes—gaze, gesture, PIN, spatial, and recognition-based—analyzing their effectiveness, security, and usability in AR/VR to address key research questions.

- ***RQ1:*** *How do different types of knowledge-based authentication schemes (gaze-based, gesture-based, PIN-based, spatial, and recognition-based) compare in terms of effectiveness, security, and usability in AR/VR environments?*
- ***RQ2:*** *How well do existing AR/VR authentication methods align with key usability and security criteria commonly used for evaluation?*
- ***RQ3:*** *What are the most promising directions for the future development of AR/VR authentication schemes, considering the balance between security, usability, and seamless integration with immersive experiences?*

Our study makes the following key **contributions**:

- We provide an in-depth evaluation of 17 knowledge-based authentication schemes, spanning five categories, offering a clear comparison of their effectiveness, security, and usability in immersive AR/VR environments.
- We propose a standardized framework for assessing usability, effectiveness, and security in AR/VR authentication, enabling a more consistent and insightful evaluation of current methods while highlighting critical areas for improvement.
- Finally, we identify the promising authentication schemes and highlight future research opportunities, guiding the development of secure, intuitive, and seamlessly integrated authentication systems for the next generation of AR/VR experiences.

2 Related Work

Prior works have explored various approaches to authentication in immersive environments, leveraging the unique affordances of AR/VR systems while addressing their specific challenges [59]. Traditional authentication methods, such as alphanumeric passwords and PINs, have been adapted for use in AR/VR environments. However, these approaches face usability issues due to the limitations of input methods in immersive settings which led to the development of novel authentication schemes that take advantage of the spatial and interactive nature of AR/VR technologies [52].

- *Naheem Noah is with University of Denver. E-mail: naheem.noah@du.edu*
- *Sanchari Das is with George Mason University. E-mail: sdas35@gmu.edu*

Received 18 September 2024; revised 13 January 2025; accepted 13 January 2025.
Date of publication 10 March 2025; date of current version 31 March 2025.
Digital Object Identifier no. 10.1109/TVCG.2025.3549862

Authorized licensed use limited to: COLORADO STATE UNIVERSITY. Downloaded on May 06,2026 at 22:35:46 UTC from IEEE Xplore. Restrictions apply.
1077-2626 © 2025 IEEE. All rights reserved, including rights for text and data mining, and training of artificial intelligence and similar technologies.
Personal use is permitted, but republication/redistribution requires IEEE permission. See https://www.ieee.org/publications/rights/index.html for more information.

Knowledge-based authentication schemes for AR/VR can be broadly classified into several categories based on their input modalities and interaction techniques. Gaze-based authentication utilizes eye movements as a means of input for authentication which leverages the eye-tracking capabilities often present in AR/VR headsets while gesture-based authentication uses hand or body gestures for authentication, taking advantage of the spatial tracking capabilities of AR/VR systems. PIN-based authentication similar to traditional PINs, often incorporates AR/VR-specific interactions and Spatial authentication schemes leverage the three-dimensional nature of AR/VR environments with virtual object manipulation in a 3D space for authentication. Recognition-based authentication on the other hand relies on the user's ability to recognize pre-selected items or patterns. Each of these categories presents unique advantages and challenges in terms of security, usability, and suitability for AR/VR environments.

Bonneau et al.'s framework [5] has been widely adopted in authentication research due to its comprehensive approach to evaluating authentication schemes across usability, deployability, and security dimensions. While originally developed for web authentication, the framework has been adapted and applied to various contexts, including mobile and AR/VR authentication. The application of Bonneau's framework in AR/VR authentication research has helped standardize the evaluation of novel schemes, allowing for more direct comparisons between different approaches. However, it's important to note that the unique characteristics of AR/VR environments often necessitate adjustments to the framework's criteria to fully capture the nuances of immersive authentication [49]. Researchers have also reviewed the several authentication schemes deployed in AR/VR environments. While Düzgün et al. [23] conducted a systematization of knowledge on knowledge-based authentication for AR head-mounted displays, Stephenson et al. [65] performed a broader survey of the authentication landscape on AR/VR devices, and Jones et al. [38] provided an overview of authentication methods for VR environments. More recent works such as Hallal et al. [31] presented a broad survey of authentication trends in extended reality, however, their work did not provide an in-depth analysis of effectiveness metrics or standardized evaluation criteria. Similarly, Kürtünlüoğlu et al. [45] focused on authentication methods specifically in the context of metaverse applications. Their work emphasized theoretical security aspects but did not provide detailed usability evaluations or quantitative comparisons of different schemes.

Our work advances beyond these previous surveys in several distinctive ways. We introduce a comprehensive framework that combines effectiveness metrics, security measures, and usability factors specifically designed for AR/VR environments, allowing for consistent evaluation across different authentication schemes. Unlike previous surveys that primarily provided qualitative overviews, our work includes a detailed technical evaluation of 17 distinct knowledge-based authentication schemes across five categories (gaze-based, gesture-based, PIN-based, spatial, and recognition-based), offering concrete performance metrics and comparisons. We apply and adapt Bonneau et al.'s framework specifically for AR/VR contexts, providing a structured evaluation of security properties that considers the unique characteristics of immersive environments. Furthermore, we place particular emphasis on usability metrics and user experience in immersive environments, an aspect not deeply explored in previous surveys. Furthermore, our work addresses the limitation identified by Düzgün et al. regarding the lack of evaluation for shoulder-surfing resistance by including this as a key security metric in our analysis.

3 Method

Our study employs a systematic review to evaluate knowledge-based authentication schemes in AR and VR environments.

3.1 Scheme Collection

Our study employs a review methodology following the PRISMA (Preferred Reporting Items for Systematic Reviews and Meta-Analyses) guidelines [54]. We conducted our literature search across four major academic databases: ACM Digital Library, Science Direct, IEEE Xplore, and SpringerLink. These databases were chosen for their extensive coverage of computer science, human-computer interaction, and AR/VR research. Following the PRISMA framework, our review process consisted of four phases: identification, screening, eligibility, and inclusion. We used a complex search string that combined terms related to AR/VR technologies, knowledge-based authentication, and access control methods. The complete list of keywords is ("Augmented Reality" OR "Mixed Reality" OR "Virtual Reality" OR "Extended Reality" OR "AR" OR "MR" OR "VR" OR "XR" OR "smart glasses" OR "smartglasses" OR "wearable glasses" OR "head-mounted display" OR "head-mounted device" OR "HMD" OR "wearable device" OR "smart eye-wear" OR "immersive technology") AND ("knowledge-based" OR "knowledge-base" OR "knowledge base" OR "KBA" OR "memory-based" OR "recall-based" OR "recognition-based" OR "secret knowledge" OR "personal knowledge" OR "shared secret" OR "passphrase") AND ("authentication" OR "password entry" OR "user verification" OR "identity verification" OR "access control" OR "login" OR "sign in"). This search initially returned $1,247$ papers. We then applied a rigorous three-stage screening process, using inclusion criteria that focused on peer-reviewed, English-language articles about knowledge-based authentication in AR/VR environments. We excluded traditional PIN schemes and popular SWIPE mobile device authentication systems to prioritize novel AR/VR-specific methods. After abstract screening, we narrowed the pool to 183 papers, and a full-text review further reduced it to 50. To ensure that each study provided comprehensive evaluations of authentication schemes, we applied additional selection criteria:

- The scheme must explore authentication effectiveness using quantitative metrics such as Accuracy Score, Success Rate, False Acceptance Rate (FAR), False Rejection Rate (FRR), and/or Equal Error Rate (EER).
- The scheme must have explored security evaluations through quantitative metrics such as Entropy Level, Zero Effort Attack success rate, Shoulder-surfing (or Observational) Attack success rate, and Random Guessing Attack success rate; or subjective qualitative assessments such as Perceived Security or Perceived Security to Shoulder-surfing.
- The scheme must have explored usability evaluations through quantitative metrics such as Enrollment Time, Authentication Time, and Memorability; or subjective qualitative assessments of perceived usability such as System Usability Scale (SUS) Score, Ease of Use, Password Memorability, and Login Speed.

Each of the 50 papers from the full-text screening underwent a systematic evaluation process. The selection criteria and evaluation rubric were developed collaboratively by all authors to ensure consistency and rigor while the final filtering was conducted by the first author. Papers meeting all four criteria were included in the final analysis. This process resulted in the selection of 10 papers describing 17 distinct authentication schemes, which form the core dataset for our analysis. To validate our final selection, we performed a backward reference search on these 10 papers, checking their reference lists for any additional relevant papers that might have been missed in our initial search. This process did not yield any additional authentication schemes.

3.2 Scheme Evaluation

Upon collecting the resulting schemes, we performed an evaluation that comprises three main components: Effectiveness Evaluation, Security Evaluation, and Usability Evaluation. Each of these components includes several specific criteria which we have added based on our review of prior works. Then we extended the criteria with Bonneau et al.'s framework [5]. Figure 1 provides an overview of the evaluation criteria and we have discussed the sub-criteria in detail below.

3.2.1 Effectiveness Evaluation

We evaluate the effectiveness of each authentication scheme based on its ability to correctly authenticate legitimate users and reject imposters. The criteria for measuring effectiveness are:

Accuracy Score: We measure the frequency of correct decisions made

Authorized licensed use limited to: COLORADO STATE UNIVERSITY. Downloaded on May 06,2026 at 22:35:46 UTC from IEEE Xplore. Restrictions apply.

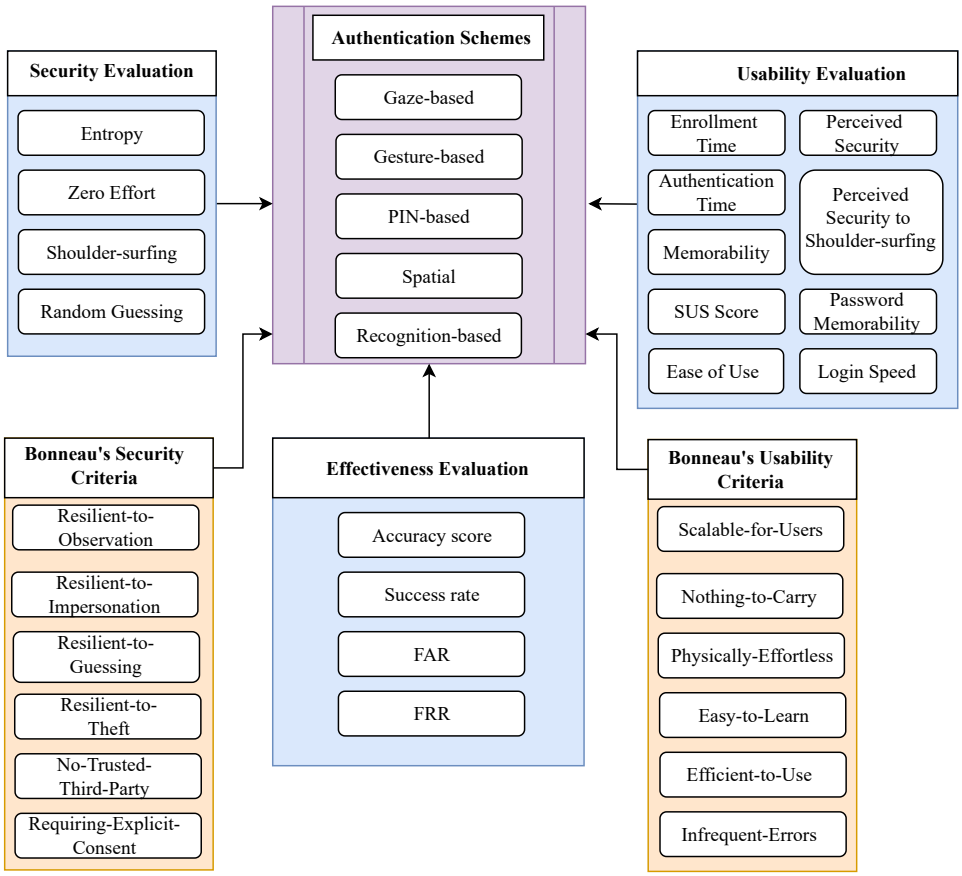

Fig. 1: Overview of Evaluation Framework Consisting of Security, Usability, and Effectiveness Criteria for AR/VR Authentication Schemes
Diagram showing the evaluation framework for AR/VR authentication schemes. It consists of three main branches: Security Evaluation (entropy, attacks, etc.), Usability Evaluation (time metrics, user perception, etc.), and Effectiveness Evaluation (accuracy scores, success rates, etc.). These all connect to five types of Authentication Schemes: Gaze-based, Gesture-based, PIN-based, Spatial, and Recognition-based.

Authorized licensed use limited to: COLORADO STATE UNIVERSITY. Downloaded on May 06,2026 at 22:35:46 UTC from IEEE Xplore. Restrictions apply.

by the authentication scheme [36]. It is calculated as (True Positives + True Negatives) / Total Attempts. A higher accuracy score indicates better overall performance.

Success Rate: This metric represents the percentage of successful authentication attempts made by legitimate users [42]. It is calculated as (Successful Attempts / Total Attempts) $*$ 100%. A higher success rate reflects better usability for legitimate users.

False Acceptance Rate (FAR): FAR measures the proportion of authentication attempts by imposters that are incorrectly accepted [56]. It is calculated as (False Positives / Total Imposter Attempts) $*$ 100%. Lower FAR values indicate stronger security.

False Rejection Rate (FRR): FRR is the percentage of legitimate user attempts that are incorrectly rejected [56]. It is calculated as (False Negatives / Total Legitimate Attempts) $*$ 100%. A lower FRR indicates better usability.

Equal Error Rate (EER): EER represents the point where FAR equals FRR on a Detection Error Tradeoff (DET) curve. DET curves plot FAR against FRR at various threshold settings, providing a visual representation of the trade-off between false acceptances and rejections [48]. A lower EER suggests better overall performance as it indicates a better balance between security (low FAR) and usability (low FRR).

3.2.2 Security Evaluation

We assess the security of each scheme based on its resilience to various attacks. The criteria for evaluating security are:

Entropy Level: This metric reflects the unpredictability of the authentication secret [62], typically measured in bits. Higher entropy increases resistance to guessing attacks.

Zero Effort Attack: This evaluates the scheme's resistance to attacks where an imposter makes authentication attempts based on likely user choices without any prior knowledge or observation of the legitimate user's behavior [4].

Random Guessing Attack: This assesses the scheme's ability to withstand attacks where an imposter makes completely random authentication attempts, selecting from all possible inputs with equal probability [19]. Unlike Zero Effort attacks, Random Guessing does not make assumptions about likely user choices or common patterns.

Shoulder-surfing or Observational Attack: This criterion measures the scheme's resistance to observation-based attacks, where an imposter watches the user during authentication [2]. This is especially important in AR/VR where users' actions may be visible.

3.2.3 Usability Evaluation

We evaluate usability based on how easy, efficient, and satisfying the authentication scheme is for users in AR/VR environments. The evaluation includes both objective and subjective criteria:

Objective Measures

Enrollment Time: We measure the time it takes for a new user to set up their authentication secret [25], typically in seconds. Shorter enrollment times indicate lower effort for initial setup.

Authentication Time: This metric captures the time required to complete the authentication process [25], measured in seconds. Faster times suggest greater efficiency.

Memorability: We assess how well users can recall their authentication secret over time, often by asking them to attempt authentication after a delay (e.g., one week) [6]. Success rates in delayed trials indicate long-term usability.

Subjective Measures

System Usability Scale (SUS) Score: This is a standardized measure of perceived usability based on a 10-item questionnaire [67]. It gives a score from 0 to 100, high scores mean better usability.

Perceived Security: We gauge users' feelings about the security of the scheme through surveys using Likert scales [32]. High perceived security increases user trust and adoption.

Perceived Security to Shoulder-surfing: We assess users' perceptions of the scheme's ability to resist observation attacks, a crucial factor in AR/VR where actions may be more visible [16].

Ease of Use: This metric captures users' overall perceptions of how easy the scheme is to use, typically gathered through surveys [61]. It can reveal usability issues not evident in objective measures.

Password Memorability: We assess users' confidence in remembering their authentication secret. This metric highlights user comfort with long-term use [61].

Login Speed: This metric reflects users' perception of how quickly they can complete the authentication process [68]. It may sometimes differ from measured authentication time.

3.2.4 Bonneau's Framework Criteria

We applied the framework to evaluate each authentication scheme's usability and security in a standardized manner [5]. We focused on usability and security criteria specifically relevant to AR/VR.

Usability Criteria

Scalable-for-Users: In AR/VR environments, we assess how easily users can apply the authentication scheme across various applications or devices without increasing cognitive load. For instance, a gesture-based password that consistently works across multiple AR/VR platforms is considered highly scalable.

Nothing-to-Carry: We evaluate whether the authentication scheme requires any additional physical objects. In AR/VR, where users already interact with headsets or controllers, an ideal scheme would not need any extra device.

Physically-Effortless: We measure the physical effort required to complete authentication. For example, a gaze-based method demands less physical effort than hand gestures, making it more physically effortless.

Easy-to-Learn: We determine how quickly users can learn and adapt to the authentication scheme in AR/VR. Schemes that use intuitive interactions within the virtual space score higher.

Efficient-to-Use: We evaluate how efficiently users can authenticate without disrupting their immersive experience. In AR/VR, quicker schemes that maintain user immersion score higher.

Infrequent-Errors: We examine how often errors occur during authentication. In AR/VR, schemes that minimize input mistakes due to challenges such as limited fields of view score better.

Security Criteria

Resilient-to-Observation: We assess how well the scheme resists attacks based on observing the authentication process. In AR/VR, this includes both physical observation of user movements and digital observation within the virtual environment. Schemes that remain secure after being observed score higher.

Resilient-to-Impersonation: We measure the scheme's ability to prevent impersonation attacks, where an adversary mimics the legitimate user's gestures, behaviors, or biometrics. In AR/VR, schemes that are difficult to impersonate, even with access to user behavior data, rank higher.

Resilient-to-Guessing: We evaluate how effectively the scheme resists guessing attacks, whether random or educated. In AR/VR, this involves guessing based on common user behaviors or predictable spatial/gesture-based inputs. Schemes with larger, less predictable secret spaces score better.

Resilient-to-Theft: For schemes that rely on external devices, we assess how secure they remain if the device is stolen. In AR/VR environments, users often use headsets or controllers, so ensuring security in the event of theft is crucial.

No-Trusted-Third-Party: We check whether the scheme relies on third-party services that could compromise security if breached. In AR/VR, authentication systems that do not depend on external servers or third parties are more secure and score higher.

Requiring-Explicit-Consent: We assess whether the scheme requires clear, intentional user actions. In AR/VR, where accidental gestures or interactions could trigger unintended authentication, schemes that demand explicit user consent rank higher.

4 Background – Schemes' Details

4.1 Gaze-based Authentication

Gaze-based authentication leverages eye movements as a biometric identifier for user authentication in AR/VR environments [24, 39, 40]. From our 17 schemes, three notable gaze-based authentication schemes

Authorized licensed use limited to: COLORADO STATE UNIVERSITY. Downloaded on May 06,2026 at 22:35:46 UTC from IEEE Xplore. Restrictions apply.

have been proposed for AR/VR environments: Free-form Gaze [27] and Hide my Gaze with EOG (Closed Eye and Open Eye) [26]. The Free-form Gaze scheme developed by Friström et al. uses cameras in smart glasses to capture user-defined eye movement patterns [27]. During enrollment, users create and repeat their gaze password multiple times to generate reference templates. Authentication involves reproducing the gaze password, which is then compared to stored templates. The Hide my Gaze with EOG scheme developed by Findling, et al. utilizes closed-eye (or open-eye) gaze gestures captured through EOG sensors in smart glasses frames [26]. Enrollment involves training a personalized gesture recognition model and setting a gaze gesture password. Authentication requires users to perform their closed-eye gaze password, which is then processed, recognized, and compared to a stored hash.

4.2 Gesture-based Authentication

Gesture-based authentication leverages physical movements or gestures as a means of user verification [41, 58]. There is a trade-off between gesture complexity for security and ease of memorability for users. Three notable gesture-based authentication schemes have been proposed for AR/VR environments: GlassPass [35], Beat-PIN [34], and In-Air-Handwriting [47]. GlassPass, developed by Islam et al. utilizes tapping gestures on the temple or arm of smart glasses for password entry. During enrollment, users either choose or are assigned a sequence of four gestures from a set of ten available tapping gestures performed with one or two fingers [35]. For authentication, users reproduce their four-gesture password sequence on the touch sensor of the smart glasses. The system provides visual feedback through the private display of the smart glasses. Beat-PIN, proposed by Hutchins et al. on the other hand employs a rhythm-based password where users tap a sequence of beats on a device's touch sensor [34]. During enrollment, users create and repeat their Beat-PIN seven times using a smartwatch, with the system recording tap timing and intervals to create a user profile. Authentication involves entering the Beat-PIN, with the system comparing the entered rhythm to the stored profile using a vector comparison algorithm. The In-Air-Handwriting scheme, developed by Lu et al. combines elements of gesture recognition, signature verification, and password systems. Users enroll by choosing a passcode string and writing it in the air five times to generate templates [47]. Authentication requires users to write their passcode in the air, with the system capturing the gesture via camera or sensors, extracting features, and comparing them to stored templates.

4.3 PIN-based Authentication

PIN-based authentication adapts the familiar concept of personal identification numbers to immersive contexts [18, 33, 59, 66]. There is also a trade-off between PIN complexity for security and ease of memorability for users. Nine notable PIN-based authentication schemes have been proposed for AR/VR environments: RubikAuth (Eye Gaze, Head Pose, and Controller Tapping) [50], CueVR [1], VBP and TBP [70], and gTapper, gRotator, gTalker [46]. RubikAuth, developed by Mathis et al., uses a virtual 3D cube resembling a Rubik's cube for PIN entry [50]. Users authenticate by selecting digits displayed on the cube's surfaces using eye gaze, head pose, or controller tapping. While the paper doesn't explicitly describe enrollment, users likely set up a PIN by selecting a sequence of digits from the cube's surfaces. The authentication process involves manipulating the cube and selecting digits using one of the three input methods. CueVR, proposed by Abdehrahman et al., is a cue-based authentication scheme that requires users to enter a 4-digit PIN guided by visual cues [1]. During authentication, users are presented with a virtual PIN pad split into two color-coded sides, with each digit randomly assigned one of five visual cues. Users must choose the correct color side and provide input based on the cue using trackpad, motion controller, or laserpointer methods. Yadav et al. introduced Voice-Based PIN (VBP) and Touch-Based PIN (TBP) for Google Glass [70]. In VBP, users speak cipher digits corresponding to their PIN based on a displayed mapping grid. TBP involves navigating a randomly arranged digit grid using touchpad swipes and taps. Both methods aim to protect against shoulder surfing by leveraging the private display of Google Glass. Li et al. developed gTapper, gRotator, and gTalker for smart glasses [46]. These schemes use finger swipes/taps, head rotations, and voice inputs respectively to enter password elements based on a hidden random keypad displayed on the smart glasses.

4.4 Spatial Authentication

Spatial authentication in AR/VR environments leverages three-dimensional capabilities, allowing users to authenticate using spatial memory and interactions within virtual or augmented spaces. This approach offers enhanced memorability, increased resistance to shoulder-surfing attacks, and the ability to create complex yet intuitive authentication sequences [3, 43, 49]. However, challenges include difficulties in consistently reproducing precise spatial interactions, potential vulnerability to observation attacks in shared spaces, and increased cognitive load [17, 29, 60]. Only one scheme fell in this category in our collection; RoomLock, developed by George et al. [28]. This scheme allows users to manipulate object positions in a virtual 3D room with nine selectable objects. Users authenticate by selecting four objects in the correct sequence using a VR headset and controller. RoomLock provides visual and haptic feedback and explores security-enhancing variations such as randomized starting positions and object placements.

4.5 Recognition-based Authentication

Recognition-based authentication in AR/VR environments leverages the human brain's superior ability to recognize visual information rather than recall it from memory [20]. This approach offers enhanced memorability, the potential for increased password complexity without sacrificing usability, and visually engaging authentication experiences [69]. However, it can be vulnerable to shoulder-surfing attacks and may be impacted by the limited field of view in some AR/VR devices [29, 44]. There is also a trade-off between the number of recognition elements presented and the time and cognitive load required for authentication [23]. Only one scheme fell into this category in our collection; Things, developed by Reyhan et al. for AR [22]. This graphical password system requires users to select specific images from grids of object images. During enrollment, users are assigned a five randomly generated images. For authentication, users select their password images from a series of five grids, each containing 16 images, using air-tap gestures on the Microsoft HoloLens.

5 Findings

5.1 Effectiveness Comparison

In our analysis, we examined five key effectiveness metrics: Accuracy Score, Success Rate, FAR, FRR, and EER though reporting coverage varied substantially across schemes. The distribution of schemes exploring each criterion varied: Accuracy Score: 5 out of 17 schemes (29.4%), Success Rate: 11 out of 17 schemes (64.7%), FAR: 4 out of 17 schemes (23.5%), FRR: 3 out of 17 schemes (17.6%), EER: 7 out of 17 schemes (41.2%). This inconsistent reporting of metrics poses challenges for direct comparisons. For example, while some schemes reported error rates (FAR, FRR, and EER), others only provided basic success rates. The reported accuracy scores ranged from 80% to 96%. Mathis et al.'s RubikAuth variants showed the highest accuracy, with Controller Tapping achieving 96%, followed by Head Pose at 92.16% and Eye Gaze at 88.23%. Findling et al.'s gaze-based schemes showed lower but still notable accuracy, with Open Eyes at 86.5% and Closed Eyes at 80%. These results suggest that physical interaction methods (like controller tapping) may offer higher accuracy than gaze-based methods in AR/VR environments. The reported Success Rates ranged from 44.7% to 98.3%. Li et al.'s schemes (gTapper, gRotator, and gTalker) demonstrated the highest Success Rates, all above 98%. This suggests excellent user performance for these head-mounted device-based authentication methods. George et al.'s RoomLock also showed a high Success Rate of 97.22%, indicating strong user performance in spatial authentication tasks. In contrast, Findling et al.'s gaze-based schemes (Closed Eyes and Open Eyes) showed the lowest Success Rates at 44.7% and 54.8% respectively. This suggests that gaze-based methods, particularly those involving closed eyes, may present challenges in consistent user performance.

Authorized licensed use limited to: COLORADO STATE UNIVERSITY. Downloaded on May 06,2026 at 22:35:46 UTC from IEEE Xplore. Restrictions apply.

Table 1: Summary of Effectiveness, Security, Usability,Perceived Usability & Security Metrics Across Authentication Schemes

		Effectiveness					Security				Usability			Perceived Security & Usability						
Authentication	**Scheme [Reference]**	Accuracy Score	Success Rate	FAR	FRR	EER	Entropy Level	Zero Effort Attack	Shoulder-surfing or Observational Attack	Random Guessing Attack	Enrollment Time	Authentication Time	Memorability	SUS Score	Perceived Security	Perceived Security to Shoulder-surfing	Ease of Use	Password Memorability	Login Speed	Future Recommendation
Gaze-based	Free-form gaze [27]	–	–	△	△	△	–	–	●	–	–	●	–	–	△	●	△	–	–	–
	Closed Eyes [26]	△	△	–	–	–	–	–	●	–	–	●	–	–	–	–	–	–	–	–
	Open Eyes [26]	△	△	–	–	–	–	–	△	–	–	●	–	–	–	–	–	–	–	–
Gesture-based	GlassPass [35]	–	●	–	–	●	△	–	–	–	–	●	△	–	–	–	–	–	–	–
	Beat-PIN [34]	–	–	●	●	●	●	●	△	–	●	●	–	–	–	–	–	–	–	–
	In-Air-Handwriting [47]	–	–	△	△	●	–	–	△	–	–	–	–	–	●	●	●	●	●	●
PIN-based	RubikAuth(Eye Gaze) [50]	△	–	–	–	–	–	–	●	–	–	●	●	–	–	–	–	–	–	●
	RubikAuth(Head Pose) [50]	●	–	–	–	–	–	–	●	–	–	●	●	–	–	–	–	–	–	△
	RubikAuth(Controller) [50]	●	–	–	–	–	–	–	●	–	–	●	●	–	–	–	–	–	–	△
	CueVR [1]	–	△	–	–	△	△	–	–	–	–	●	–	–	–	–	–	–	–	–
	VBP [70]	–	△	–	–	△	△	–	–	–	–	●	–	●	●	△	●	–	●	●
	TBP [70]	–	△	–	–	△	△	–	–	–	–	●	–	●	●	△	△	–	△	●
	gTapper [46]	–	●	–	–	–	●	–	–	–	–	●	–	–	–	–	–	–	–	●
	gRotator [46]	–	●	–	–	–	●	–	–	–	–	●	–	–	–	–	–	–	–	△
	gTalker [46]	–	●	–	–	–	●	–	–	–	–	●	–	–	–	–	–	–	–	●
Spatial	RoomLock [28]	–	●	●	–	–	–	–	△	△	–	●	△	–	–	–	–	–	–	–
Recognition-based	Things [22]	–	●	–	–	–	●	–	–	–	△	●	–	●	●	●	●	●	●	●

Among the schemes reporting FAR and FRR, Lu et al.'s In-Air-Handwriting (camera) showed a low FAR of 0.12 but a relatively high FRR of 3.23, indicating a tendency towards false rejections. Hutchins et al.'s Beat-PIN reported balanced FAR and FRR values of 0.072, suggesting a trade-off between security and usability. EER values, when reported, ranged from 0.05 to 0.179. Islam et al.'s GlassPass demonstrated the lowest EER of 0.05, indicating a good balance between false acceptances and rejections. In contrast, Abdehrahman et al.'s CueVR showed the highest EER of 0.179, suggesting room for improvement in balancing security and usability. The varied reporting of effectiveness metrics across schemes makes comparisons challenging. However, the available data suggests that some novel AR/VR authentication schemes, particularly those leveraging PIN input can achieve high success rates and accuracy scores. Gaze-based methods, while innovative, seem to face more challenges in terms of accuracy and success rates. Table 1 shows the summary of the Effectiveness evaluation of the schemes. A detailed explanation of the rating symbols and thresholds can be found in Table 2 in the Appendix.

5.2 Security Analysis

The security of authentication schemes in AR/VR environments is crucial for protecting user data and privacy. Our analysis focused on four key security metrics: Entropy Level, Zero Effort Attack, Shoulder-surfing or Observational Attack, and Random Guessing Attack. The distribution of these metrics across the evaluated schemes varied substantially. The distribution of Security Metrics includes Entropy levels: 9 out of 17 schemes (52.9%). Zero Effort Attack: 1 out of 17 schemes (5.9%), Shoulder-surfing or Observational Attack: 9 out of 17 schemes (52.9%), and Random Guessing Attack: 1 out of 17 schemes (5.9%).

It is important to note that for Entropy levels, some schemes explicitly mentioned it, while for others, we calculated the entropy based on our understanding of the enrollment and authentication parameters. For schemes where neither was available, we did not explore the entropy. The reported Entropy Levels ranged from 13.29 bits to 140 bits. Hutchins et al.'s Beat-PIN demonstrated the highest entropy at 140 bits, suggesting a large password space and high theoretical security against guessing attacks. In contrast, several schemes including CueVR, VBP, TBP, and GlassPass reported an entropy of 13.29 bits, which is equivalent to that of traditional 4-digit PINs. Li et al.'s schemes (gTapper, gRotator, and gTalker) showed improved entropy at 19.93 bits, while Reyhan et al.'s Things scheme reached 20 bits, indicating a larger password space and potentially higher security against brute-force attacks.

Nine schemes provided data on shoulder-surfing resistance, with results varying widely. Mathis et al.'s RubikAuth variants showed high resistance, with success rates for users during attacks ranging from 96% to 99.55%. However, it is important to note that in this context, higher percentages indicate better resistance to shoulder-surfing attacks. Findling et al.'s Closed Eyes gaze-based scheme demonstrated perfect resistance to shoulder-surfing, with no successful attacks. However, their Open Eyes scheme was more vulnerable, with attackers succeeding in 61% of cases. George et al.'s RoomLock showed strong resistance, with only 12.5% of attacks being successful and Friström et al.'s Free-form Gaze demonstrated good resistance, with attackers succeeding only in 17.5% of cases. Lu et al.'s In-Air-Handwriting (camera) reported a 1.9 EER for shoulder-surfing attacks, indicating good resistance. Only Hutchins et al.'s Beat-PIN reported on Zero Effort Attack, with a FAR of 0.082 and only George et al.'s RoomLock reported on Random Guessing Attack, with an 18.5% success rate for attackers.

While some novel approaches like Beat-PIN offer high theoretical security through large password spaces, others may be more vulnerable to certain types of attacks. Gaze-based methods and spatial authentication techniques show promise in resisting shoulder-surfing, particularly when users' eyes are closed or when using 3D environments. However, the limited reporting of Zero Effort and Random Guessing Attacks (only one scheme each) highlights a major gap in security evaluation. Table 1 shows the summary of the Security evaluation of the schemes.

Authorized licensed use limited to: COLORADO STATE UNIVERSITY. Downloaded on May 06,2026 at 22:35:46 UTC from IEEE Xplore. Restrictions apply.

A detailed explanation of the rating symbols and thresholds can be found in Table 2 in the Appendix.

5.3 Usability Evaluation

Our analysis of the usability of authentication schemes in AR/VR environments focused on three key metrics: Enrollment Time, Authentication Time, and Memorability. The distribution of schemes exploring each criterion varied markedly, with 2 out of 17 schemes (11.8%) reporting Enrollment Time, 16 out of 17 schemes (94.1%) reporting Authentication Time, and 5 out of 17 schemes (29.4%) exploring Memorability.

For Enrollment Time, only two schemes provided data: Reyhan et al.'s Things (62.21 seconds) and Hutchins et al.'s Beat-PIN (12.3 seconds). The substantial difference between these times suggests that the complexity and nature of the authentication method can greatly impact the initial setup time for users. Things, being a graphical password system, requires more time for users to familiarize themselves with the image selection process, while Beat-PIN's rhythm-based approach appears to be quicker to set up. Authentication Time was the most widely reported metric, with reported times ranging from 1.69 seconds to 32.2 seconds. The fastest authentication times were reported for Mathis et al.'s RubikAuth variants, with Controller Tapping being the quickest at 1.69 seconds, followed closely by Head Pose (2.35 seconds) and Eye Gaze (2.39 seconds). This suggests that physical interaction methods in VR environments can lead to rapid authentication. In contrast, Reyhan et al.'s Things scheme had the longest authentication time at 32.2 seconds, which may be due to the complexity of selecting specific images from grids in an AR environment. Among the other schemes, Beat-PIN by Hutchins et al. showed a quick authentication time of 1.7 seconds, while GlassPass by Islam et al. demonstrated efficiency with a 2.3-second authentication time. Gaze-based methods (Findling et al.'s Closed Eyes and Open Eyes) showed moderate authentication times of 10.8 and 10 seconds respectively, while voice-based methods like Li et al.'s gTalker had longer authentication times (21.8 seconds), possibly due to the time required for speech recognition and processing.

Memorability was explored by only 5 out of 17 schemes, with results reported as success rates after a period of time. Mathis et al.'s RubikAuth variants (Eye Gaze, Head Pose, Controller Tapping) all showed high memorability with a 95.24% success rate, while George et al.'s RoomLock demonstrated good memorability with a 77.78% success rate. Islam et al.'s GlassPass showed moderate memorability with a 67% success rate. These results suggest that spatial and physical interaction-based methods in VR (like RubikAuth and RoomLock) may offer better memorability compared to more traditional approaches like GlassPass. Table 1 shows the summary of the Usability evaluation of the scheme. A detailed explanation of the rating symbols and thresholds can be found in Table 2 in the Appendix.

5.3.1 User Perception Analysis

Our analysis of perceived security and usability focused on seven metrics, though reporting rates varied considerably: SUS Score, Perceived Security, Perceived Security to Shoulder-surfing, Ease of Use, Password Memorability, Login Speed, and Future Recommendations. It is important to note that apart from the SUS score (which ranges from 0 to 100), all other criteria were evaluated on a 5-point Likert scale. In cases where papers used different rating scales, we normalized the results to a 5-point scale for consistency. The distribution of schemes exploring each criterion varied substantially: SUS Score: 3 out of 17 schemes (17.6%), Perceived Security: 5 out of 17 schemes (29.4%). Perceived Security to Shoulder-surfing: 5 out of 17 schemes (29.4%), Ease of Use: 5 out of 17 schemes (29.4%), Password Memorability: 2 out of 17 schemes (11.8%), Login Speed: 3 out of 17 schemes (17.6%), and Future Recommendation: 10 out of 17 schemes (58.8%).

SUS scores were reported for only three schemes. Yadav et al.'s Voice-Based PIN (VBP) achieved the highest score of 76.1, followed by Reyhan et al.'s Things at 74, and Yadav et al.'s Touch-Based PIN (TBP) at 69.1. These scores suggest that all three schemes have above-average usability, with VBP and Things approaching the "good" usability threshold of 80. Perceived Security was highest for Lu et al.'s In-Air-Handwriting (camera) and Yadav et al.'s VBP and TBP schemes, all scoring above 4 out of 5. In contrast, Friström et al.'s Free-form Gaze received a lower score of 2.88, suggesting users felt less confident about its security. Perceived Security to Shoulder-surfing varied widely. Reyhan et al.'s Things scored highest at 3.94, while Yadav et al.'s VBP and TBP scored lowest at 1.93 and 2.07 respectively, indicating users felt these schemes were more vulnerable to shoulder-surfing attacks.

Ease of Use ratings were generally positive, with Lu et al.'s In-Air-Handwriting (camera) and Reyhan et al.'s Things scoring 4 out of 5. However, Friström et al.'s Free-form Gaze scored only 2.18, suggesting users found it more challenging to use. Password Memorability was only reported for two schemes, with both scoring high: Lu et al.'s In-Air-Handwriting (camera) at 4.3 and Reyhan et al.'s Things at 4.31. Login Speed was reported for three schemes, with Lu et al.'s In-Air-Handwriting (camera) scoring highest at 3.8, followed by Reyhan et al.'s Things at 3.19, and Yadav et al.'s TBP scoring lowest at 2.33. Future Recommendation scores were available for the most schemes, providing insight into overall user satisfaction. Li et al.'s gTapper received the highest score of 5, indicating strong user preference. In contrast, Mathis et al.'s Controller Tapping and Head Pose variants of RubikAuth received low scores of 0.87 and 1.09 respectively, suggesting users were less likely to recommend these methods.

Overall, schemes that balance security with ease of use, such as In-Air-Handwriting and Things, tend to be perceived more favorably by users. However, the limited exploration of some criteria across many schemes highlights the need for more usability evaluations in future research. Table 1 shows the summary of the Usability evaluation of the scheme. A detailed explanation of the rating symbols and thresholds can be found in Table 2 in the Appendix.

5.4 Bonneau's Framework Analysis

5.4.1 Usability criteria comparison

We evaluated the schemes across six usability criteria from Bonneau et al.'s framework: Scalable-for-Users, Nothing-to-Carry, Physically-Effortless, Easy-to-Learn, Efficient-to-Use, and Infrequent-Errors. Our analysis reveals that all 17 schemes (100%) were rated positively for: Scalable-for-Users and Efficient-to-Use as the schemes can be used across AR and VR environments, and these AR/VR authentication methods generally allow for quick completion of the authentication process which takes less than 1 minute. Most of the schemes (16 out of 17 - 94.1%) also met Nothing-to-Carry indicating that they utilize existing AR/VR hardware without necessitating additional physical devices. The only scheme that did not meet this criterion is Beat-PIN which utilizes another device (like a smartwatch) for authentication.

Fourteen out of 17 schemes (82.4%) were rated as easy to learn. Free-form Gaze, gRotator, and In-Air-Handwriting were exceptions, possibly due to the complexity of their input methods. Also, 12 out of 17 schemes (70.6%) were considered physically effortless. Schemes requiring more complex physical interactions, such as Free-form Gaze, CueVR, gRotator, In-Air-Handwriting, and RubikAuth's Head Pose, did not meet this criterion. Infrequent-Errors was met by 11 out of 17 schemes (64.7%). The Things scheme by Reyhan et al., gTalker by Li et al., GlassPass by Islam et al., and RoomLock by George et al. met all six usability criteria, suggesting they offer a good balance of usability features for AR/VR authentication. Conversely, In-Air-Handwriting (camera) by Lu et al. met the fewest criteria, potentially indicating more considerable usability challenges. Figure 2 shows the distribution of usability criterion satisfaction based on Bonneau et al.'s framework.

5.4.2 Security criteria comparison

We evaluated 17 authentication schemes across six security criteria from Bonneau et al.'s framework: Resilient-to-Observation, Resilient-to-Impersonation, Resilient-to-Guessing, Resilient-to-Theft, No-Trusted-Third-Party, and Requiring-Explicit-Consent. All 17 schemes (100%) were rated as requiring explicit consent from the user for authentication which is a positive aspect of user control and privacy, and resilient to theft, as they often rely on user-specific interactions or biometrics rather than physical tokens that can be stolen. Similarly, almost all schemes (16 out of 17, 94.1%) did not require a

Authorized licensed use limited to: COLORADO STATE UNIVERSITY. Downloaded on May 06,2026 at 22:35:46 UTC from IEEE Xplore. Restrictions apply.

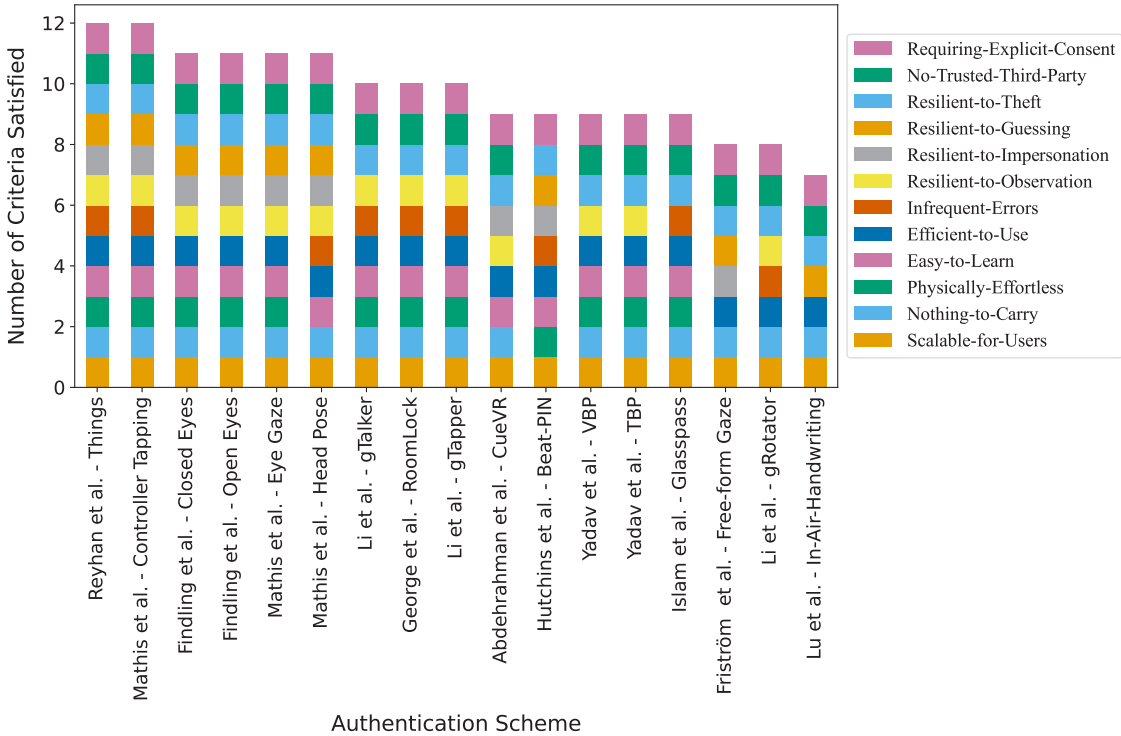

Fig. 2: Based on Bonneau et al.'s framework [5]: Distribution of Security and Usability Criterion Satisfaction Across Authentication Schemes Horizontal bar chart comparing 17 AR/VR authentication schemes based on how many security and usability criteria they meet. Each bar shows the number of criteria satisfied (from 0-12) using different colors for security criteria and usability criteria. Things and Controller Tapping schemes satisfy the most criteria, while In-Air-Handwriting satisfies the least.

trusted third party, with Beat-PIN being the only exception as it requires a smartwatch.

13 out of 17 schemes (76.5%) were rated as resilient to observation attacks. Schemes like Things, CueVR, VBP, TBP, and all variants of Li et al.'s and Mathis et al.'s schemes demonstrated this property. However, Beat-PIN, Free-form Gaze, GlassPass, and In-Air-Handwriting (camera) were not considered resilient to observation. Only 9 out of 17 schemes (52.94%) were rated as resilient to impersonation attacks. Things, Beat-PIN, Free-form Gaze, CueVR, both of Findling et al.'s gaze-based schemes, and all variants of Mathis et al.'s RubikAuth demonstrated this property. Similarly, 9 out of 17 schemes (52.9%) were considered resilient to guessing attacks. Things, Beat-PIN, Free-form Gaze, In-Air-Handwriting (camera), both of Findling et al.'s gaze-based schemes, and all variants of Mathis et al.'s RubikAuth showed this property. Interestingly Reyhan et al.'s Things, Mathis et al.'s RubikAuth variants (Eye Gaze, Head Pose, Controller Tapping), and Findling et al.'s gaze-based schemes (Closed Eyes, Open Eyes) met all six security criteria, suggesting they offer a strong balance of security features. However, GlassPass met the fewest security criteria (3 out of 6), suggesting potential vulnerabilities in observation, impersonation, and guessing resistance. Figure 2 shows the distribution of security criterion satisfaction based on Bonneau et al.'s framework.

6 Discussion

In this section, we address the research questions by analyzing the strengths and weaknesses of the authentication schemes, their alignment with usability and security criteria, and potential directions for future development.

RQ1: How do different types of knowledge-based authentication schemes compare in terms of effectiveness, security, and usability in AR/VR environments?

We evaluated 17 knowledge-based authentication schemes across five categories—gaze-based, gesture-based, PIN-based, spatial, and recognition-based—each with unique trade-offs in terms of effectiveness, security, and usability. **Gaze-based methods** are appealing for hands-free interaction and shoulder-surfing resistance but often suffer from lower accuracy and user performance, which limits their effectiveness. For instance, schemes like Closed Eyes provide high security but struggle with usability in dynamic AR/VR environments. **Gesture-based schemes**, such as Beat-PIN, achieve high theoretical security with an entropy of 140 bits, making them resistant to guessing attacks. Despite their intuitive interaction, they remain vulnerable to observation attacks, especially in shared spaces where gestures are visible. However, their seamless integration into AR/VR environments enhances usability, with fast authentication times.

PIN-based methods, like RubikAuth, offer the familiarity and speed of traditional PINs, with authentication times as low as 1.69 seconds. While efficient, these schemes do not substantially improve security compared to traditional PIN systems. **Spatial authentication** schemes, such as RoomLock, use spatial memory to create memorable and secure authentication experiences. These methods excel at resisting shoulder-surfing attacks (with an 87.5% attack failure rate) but may face challenges in frequent use due to the cognitive load involved. **Recognition-based methods**, like Things, demonstrate high usability, with a SUS score of 74, indicating strong user acceptance. However, these schemes often trade off speed for security, with longer authentication times (e.g., 32.2 seconds), which can disrupt immersion. Our analysis shows that no single method excels in all areas, reinforcing the need for hybrid approaches that combine the strengths of multiple schemes. Context-specific selection is crucial in AR/VR, where factors such as usage frequency, privacy, and user preferences vary.

RQ2: How well do existing AR/VR authentication methods align with key usability and security criteria commonly used for evaluation?

Applying established usability and security criteria to these AR/VR authentication schemes reveals their strengths and areas for improvement. We found that most schemes perform well in terms of scalability and efficiency, with 100% of schemes being scalable across platforms and

Authorized licensed use limited to: COLORADO STATE UNIVERSITY. Downloaded on May 06,2026 at 22:35:46 UTC from IEEE Xplore. Restrictions apply.

94.1% requiring nothing to carry. However, only 70.6% of schemes were physically effortless, and 64.7% had infrequent errors. Reducing physical effort and error rates is critical for improving the overall user experience and maintaining immersion in AR/VR. From a security perspective, most schemes demonstrate resilience to theft and require explicit user consent, but only 76.5% resist observation attacks, and just 52.94% and 52.9% are resilient to impersonation and guessing attacks, respectively. This highlights a persistent security-usability trade-off: while some schemes like gaze-based methods excel in security, they often struggle with usability, while more user-friendly schemes like RubikAuth may compromise on security.

RQ3: What are the most promising directions for the future development of AR/VR authentication schemes, considering the balance between security, usability, and seamless integration with immersive experiences?

Our analysis points to several promising directions for the future development of AR/VR authentication schemes. Hybrid approaches that leverage AR/VR's immersive capabilities could strike the right balance between security and usability. **Beat-PIN** stands out for its theoretical security, with an entropy of 140 bits and fast authentication time (1.7 seconds). Future work could focus on enhancing its resilience to observation attacks without sacrificing usability. **RubikAuth**, particularly its Controller Tapping variant, offers the fastest authentication time (1.69 seconds) and high accuracy (96%). Its use of 3*D* manipulation makes it well-suited for VR, and future research could adapt it for AR environments and improve its memorability. **Things**, a recognition-based scheme, balances security and usability, with a SUS score of 74. Reducing its authentication time (currently 32.2 seconds) while maintaining security could make it more practical for immersive environments.

RoomLock leverages spatial memory, offering strong resistance to shoulder-surfing attacks (87.5% attack failure rate) and a high success rate (97.22%). Future research could adapt this approach for AR environments and explore solutions for motion sickness concerns. **Gaze-based methods**, such as the Closed Eyes variant, show potential for hands-free authentication and strong resistance to shoulder-surfing. Although accuracy remains a challenge, improving gaze tracking in AR/VR could unlock the full potential of these methods. Hybrid, multimodal, or cross-modal approaches that combine spatial memory, temporal patterns, and intuitive gestures could lead to highly secure, user-friendly solutions.

Challenges in AR/VR Authentication

AR/VR authentication faces challenges in balancing security and usability, designing methods resistant to physical and virtual observation, and minimizing cognitive load to maintain immersion. High-security schemes like Beat-PIN struggle with usability, while user-friendly options like RubikAuth often lack robust security. Gaze-based methods require refinement, spatial schemes like RoomLock must address environmental variability, and temporal schemes like Beat-PIN need to handle user rhythm inconsistencies. Researchers also face evaluation challenges due to reliance on lab-based testing, a lack of standardized metrics, and inconsistent usability and security assessments, which hinder comparisons and real-world applicability.

7 Limitations and Future Work

In this study, we focused on knowledge-based authentication due to its relevance in AR/VR but plan to explore biometric and hardware-based approaches in future work. Our analysis faced limitations due to incomplete data reporting, as key metrics like enrollment times and memorability were rarely provided. The lack of standardized evaluation metrics further hindered direct comparisons, emphasizing the need for a unified framework, which we propose for future assessments. Additionally, many studies relied on controlled environments, reducing their real-world applicability, while the absence of longitudinal studies raises questions about long-term effectiveness. Future research should address these gaps by developing cross-modal and context-aware authentication techniques, establishing standardized reporting protocols, and conducting long-term, real-world evaluations.

8 Conclusion

We systematically evaluated 17 knowledge-based authentication schemes for AR/VR environments, uncovering both innovative progress and persistent challenges. Our analysis of gaze-based, gesture-based, PIN-based, spatial, and recognition-based schemes highlights advancements in leveraging immersive technologies for authentication. For instance, CueVR, VBP, TBP, and GlassPass reported low entropy of 13.29 bits, similar to traditional 4-digit PINs, while the Things scheme achieved 20 bits of entropy and a high SUS score of 74, indicating strong user acceptance despite longer authentication times. Success rates ranged from 44.7% for gaze-based Closed Eyes to over 98% for schemes like gTapper, gRotator, and gTalker. Extending Bonneau et al.'s framework to create our own, we found that while most schemes excel in scalability and efficiency, only 70.6% were physically effortless, and 64.7% demonstrated infrequent errors. To advance AR/VR authentication, researchers should prioritize developing hybrid methods that integrate seamlessly with immersive experiences, harness emerging AR/VR technologies, and conduct longitudinal studies in real-world settings.

References

[1] Y. Abdelrahman, F. Mathis, P. Knierim, A. Kettler, F. Alt, and M. Khamis. Cuevr: Studying the usability of cue-based authentication for virtual reality. In *Proceedings of the 2022 International Conference on Advanced Visual Interfaces*, pp. 1–9, 2022. 5, 6

[2] A. J. Aviv, K. Gibson, E. Mossop, M. Blaze, and J. M. Smith. Smudge attacks on smartphone touch screens. In *4th USENIX workshop on offensive technologies (WOOT 10)*, 2010. 4

[3] A. Bianchi, I. Oakley, and D. S. Kwon. The secure haptic keypad: a tactile password system. In *Proceedings of the SIGCHI Conference on Human Factors in Computing Systems*, pp. 1089–1092, 2010. 5

[4] J. Bonneau. The science of guessing: analyzing an anonymized corpus of 70 million passwords. In *2012 IEEE symposium on security and privacy*, pp. 538–552. IEEE, 2012. 4

[5] J. Bonneau, C. Herley, P. C. Van Oorschot, and F. Stajano. The quest to replace passwords: A framework for comparative evaluation of web authentication schemes. In *2012 IEEE symposium on security and privacy*, pp. 553–567. IEEE, 2012. 1, 2, 4, 8

[6] J. Bonneau and S. Schechter. Towards reliable storage of 56-bit secrets in human memory. In *23rd USENIX Security Symposium (USENIX Security 14)*, pp. 607–623, 2014. 4

[7] S. Das. *A risk-reduction-based incentivization model for human-centered multi-factor authentication*. Indiana University, 2020. 1

[8] S. Das, A. Dingman, and L. J. Camp. Why johnny doesn't use two factor a two-phase usability study of the fido u2f security key. In *Financial Cryptography and Data Security: 22nd International Conference, FC 2018, Nieuwpoort, Curaçao, February 26–March 2, 2018, Revised Selected Papers 22*, pp. 160–179. Springer, 2018. 1

[9] S. Das, A. Kim, B. Jelen, L. Huber, and L. J. Camp. Non-inclusive online security: older adults' experience with two-factor authentication. In *Proceedings of the 54th Hawaii International Conference on System Sciences*, 2020. 1

[10] S. Das, A. Kim, B. Jelen, J. Streiff, L. J. Camp, and L. Huber. Why don't older adults adopt two-factor authentication? In *Proceedings of the 2020 SIGCHI Workshop on Designing Interactions for the Ageing Populations-Addressing Global Challenges*, 2020. 1

[11] S. Das, A. Kim, S. Mare, J. Streiff, and L. J. Camp. Security mandates are pervasive: An inter-school study on analyzing user authentication behavior. In *2019 IEEE 5th International Conference on Collaboration and Internet Computing (CIC)*, pp. 306–313. IEEE, 2019. 1

[12] S. Das, G. Russo, A. C. Dingman, J. Dev, O. Kenny, and L. J. Camp. A qualitative study on usability and acceptability of yubico security key. In *Proceedings of the 7th workshop on socio-technical aspects in security and trust*, pp. 28–39, 2018. 1

[13] S. Das, B. Wang, Z. Tingle, and L. J. Camp. Evaluating user perception of multi-factor authentication: A systematic review. *arXiv preprint arXiv:1908.05901*, 2019. 1

[14] A. De Angeli, L. Coventry, G. Johnson, and K. Renaud. Is a picture really worth a thousand words? exploring the feasibility of graphical authentication systems. *International journal of human-computer studies*, 63(1-2):128–152, 2005. 1

Authorized licensed use limited to: COLORADO STATE UNIVERSITY. Downloaded on May 06,2026 at 22:35:46 UTC from IEEE Xplore. Restrictions apply.

[15] J. A. De Guzman, K. Thilakarathna, and A. Seneviratne. Security and privacy approaches in mixed reality: A literature survey. *ACM Computing Surveys (CSUR)*, 52(6):1–37, 2019. 1

[16] A. De Luca, M. Harbach, E. von Zezschwitz, M.-E. Maurer, B. E. Slawik, H. Hussmann, and M. Smith. Now you see me, now you don't: protecting smartphone authentication from shoulder surfers. In *Proceedings of the sigchi conference on human factors in computing systems*, pp. 2937–2946, 2014. 4

[17] A. De Luca, E. Von Zezschwitz, and H. Hußmann. Vibrapass: secure authentication based on shared lies. In *Proceedings of the SIGCHI conference on human factors in computing systems*, pp. 913–916, 2009. 5

[18] A. De Luca, E. Von Zezschwitz, N. D. H. Nguyen, M.-E. Maurer, E. Rubegni, M. P. Scipioni, and M. Langheinrich. Back-of-device authentication on smartphones. In *Proceedings of the sigchi conference on human factors in computing systems*, pp. 2389–2398, 2013. 5

[19] M. Dell'Amico, P. Michiardi, and Y. Roudier. Password strength: An empirical analysis. In *2010 Proceedings IEEE INFOCOM*, pp. 1–9. IEEE, 2010. 4

[20] R. Dhamija and A. Perrig. Deja {Vu–A} user study: Using images for authentication. In *9th USENIX Security Symposium (USENIX Security 00)*, 2000. 5

[21] R. Duezguen, P. Mayer, S. Das, and M. Volkamer. Towards secure and usable authentication for augmented and virtual reality head-mounted displays. *arXiv preprint arXiv:2007.11663*, 2020. 1

[22] R. Düzgün, P. Mayer, and M. Volkamer. Shoulder-surfing resistant authentication for augmented reality. In *Nordic Human-Computer Interaction Conference*, pp. 1–13, 2022. 5, 6

[23] R. Düzgün, N. Noah, P. Mayer, S. Das, and M. Volkamer. Sok: A systematic literature review of knowledge-based authentication on augmented reality head-mounted displays. In *Proceedings of the 17th International Conference on Availability, Reliability and Security*, pp. 1–12, 2022. 2, 5

[24] S. Eberz, K. B. Rasmussen, V. Lenders, and I. Martinovic. Looks like eve: Exposing insider threats using eye movement biometrics. *ACM Transactions on Privacy and Security (TOPS)*, 19(1):1–31, 2016. 4

[25] S. Egelman, S. Jain, R. S. Portnoff, K. Liao, S. Consolvo, and D. Wagner. Are you ready to lock? In *Proceedings of the 2014 ACM SIGSAC Conference on Computer and Communications Security*, pp. 750–761, 2014. 4

[26] R. D. Findling, T. Quddus, and S. Sigg. Hide my gaze with eog! towards closed-eye gaze gesture passwords that resist observation-attacks with electrooculography in smart glasses. In *Proceedings of the 17th International Conference on Advances in Mobile Computing & Multimedia*, pp. 107–116, 2019. 5, 6

[27] E. Fristrom, E. Lius, N. Ulmanen, P. Hietala, P. Kärkkäinen, T. Mäkinen, S. Sigg, and R. D. Findling. Free-form gaze passwords from cameras embedded in smart glasses. In *Proceedings of the 17th International Conference on Advances in Mobile Computing & Multimedia*, pp. 136–144, 2019. 5, 6

[28] C. George, M. Khamis, D. Buschek, and H. Hussmann. Investigating the third dimension for authentication in immersive virtual reality and in the real world. In *2019 ieee conference on virtual reality and 3d user interfaces (vr)*, pp. 277–285. IEEE, 2019. 5, 6

[29] J. Gugenheimer, C. Mai, M. McGill, J. Williamson, F. Steinicke, and K. Perlin. Challenges using head-mounted displays in shared and social spaces. In *Extended Abstracts of the 2019 CHI Conference on Human Factors in Computing Systems*, pp. 1–8, 2019. 5

[30] M. D. Hafiz, A. H. Abdullah, N. Ithnin, and H. K. Mammi. Towards identifying usability and security features of graphical password in knowledge based authentication technique. In *2008 Second Asia International Conference on Modelling & Simulation (AMS)*, pp. 396–403. IEEE, 2008. 1

[31] L. Hallal, J. Rhinelander, and R. Venkat. Recent trends of authentication methods in extended reality: A survey. *Applied System Innovation*, 7(3):45, 2024. 2

[32] M. Harbach, E. Von Zezschwitz, A. Fichtner, A. De Luca, and M. Smith. {It's} a hard lock life: A field study of smartphone ({Un) Locking} behavior and risk perception. In *10th symposium on usable privacy and security (SOUPS 2014)*, pp. 213–230, 2014. 4

[33] E. Hayashi, S. Das, S. Amini, J. Hong, and I. Oakley. Casa: context-aware scalable authentication. In *Proceedings of the Ninth Symposium on Usable Privacy and Security*, pp. 1–10, 2013. 5

[34] B. Hutchins, A. Reddy, W. Jin, M. Zhou, M. Li, and L. Yang. Beat-pin: A user authentication mechanism for wearable devices through secret beats. In *Proceedings of the 2018 on Asia Conference on Computer and Communications Security*, pp. 101–115, 2018. 5, 6

[35] M. R. Islam, D. Lee, L. S. Jahan, and I. Oakley. Glasspass: Tapping gestures to unlock smart glasses. In *Proceedings of the 9th Augmented Human International Conference*, pp. 1–8, 2018. 5, 6

[36] A. K. Jain, A. Ross, and S. Prabhakar. An introduction to biometric recognition. *IEEE Transactions on circuits and systems for video technology*, 14(1):4–20, 2004. 4

[37] K. Jensen, F. Tazi, and S. Das. Multi-factor authentication application assessment: Risk assessment of expert-recommended mfa mobile applications. *Proceeding of the Who Are You*, 2021. 1

[38] J. M. Jones, R. Duezguen, P. Mayer, M. Volkamer, and S. Das. A literature review on virtual reality authentication. In *Human Aspects of Information Security and Assurance: 15th IFIP WG 11.12 International Symposium, HAISA 2021, Virtual Event, July 7–9, 2021, Proceedings 15*, pp. 189–198. Springer, 2021. 2

[39] C. Katsini, Y. Abdrabou, G. E. Raptis, M. Khamis, and F. Alt. The role of eye gaze in security and privacy applications: Survey and future hci research directions. In *Proceedings of the 2020 CHI conference on human factors in computing systems*, pp. 1–21, 2020. 4

[40] M. Khamis, F. Alt, M. Hassib, E. von Zezschwitz, R. Hasholzner, and A. Bulling. Gazetouchpass: Multimodal authentication using gaze and touch on mobile devices. In *Proceedings of the 2016 CHI Conference Extended Abstracts on Human Factors in Computing Systems*, pp. 2156–2164, 2016. 4

[41] M. Khamis, L. Trotter, V. Mäkelä, E. v. Zezschwitz, J. Le, A. Bulling, and F. Alt. Cueauth: Comparing touch, mid-air gestures, and gaze for cue-based authentication on situated displays. *Proceedings of the ACM on Interactive, Mobile, Wearable and Ubiquitous Technologies*, 2(4):1–22, 2018. 5

[42] S. Komanduri, R. Shay, P. G. Kelley, M. L. Mazurek, L. Bauer, N. Christin, L. F. Cranor, and S. Egelman. Of passwords and people: measuring the effect of password-composition policies. In *Proceedings of the sigchi conference on human factors in computing systems*, pp. 2595–2604, 2011. 4

[43] A. Kulshreshth and J. J. LaViola Jr. Exploring the usefulness of finger-based 3d gesture menu selection. In *Proceedings of the SIGCHI Conference on Human Factors in Computing Systems*, pp. 1093–1102, 2014. 5

[44] M. Kumar, T. Garfinkel, D. Boneh, and T. Winograd. Reducing shoulder-surfing by using gaze-based password entry. In *Proceedings of the 3rd symposium on Usable privacy and security*, pp. 13–19, 2007. 5

[45] P. Kürtünlüoğlu, B. Akdik, and E. Karaarslan. Security of virtual reality authentication methods in metaverse: An overview. *arXiv preprint arXiv:2209.06447*, 2022. 1, 2

[46] Y. Li, Y. Cheng, W. Meng, Y. Li, and R. H. Deng. Designing leakage-resilient password entry on head-mounted smart wearable glass devices. *IEEE Transactions on Information Forensics and security*, 16:307–321, 2020. 5, 6

[47] D. Lu, Y. Deng, and D. Huang. Global feature analysis and comparative evaluation of freestyle in-air-handwriting passcode for user authentication. In *Proceedings of the 37th Annual Computer Security Applications Conference*, pp. 468–481, 2021. 5, 6

[48] A. F. Martin, G. R. Doddington, T. Kamm, M. Ordowski, and M. A. Przybocki. The det curve in assessment of detection task performance. In *Eurospeech*, vol. 4, pp. 1895–1898, 1997. 4

[49] F. Mathis, K. Vaniea, and M. Khamis. Prototyping usable privacy and security systems: Insights from experts. *International Journal of Human–Computer Interaction*, 38(5):468–490, 2022. 2, 5

[50] F. Mathis, J. H. Williamson, K. Vaniea, and M. Khamis. Fast and secure authentication in virtual reality using coordinated 3d manipulation and pointing. *ACM Transactions on Computer-Human Interaction (ToCHI)*, 28(1):1–44, 2021. 1, 5, 6

[51] N. Noah, P. Mayer, and S. Das. Optimizing shoulder-surfing resistance in augmented and virtual reality: A replication study proposal in the us. In *7th Workshop on Inclusive Privacy and Security (WIPS)*, 2023. 1

[52] N. Noah, P. Mayer, and S. Das. A proposal to study shoulder-surfing resistant authentication for augmented and virtual reality: Replication study in the us. In *Companion Publication of the 2023 Conference on Computer Supported Cooperative Work and Social Computing*, pp. 317–322, 2023. 1

[53] N. Noah, S. Shearer, and S. Das. Security and privacy evaluation of popular augmented and virtual reality technologies. In *Proceedings of the 2022*

Authorized licensed use limited to: COLORADO STATE UNIVERSITY. Downloaded on May 06,2026 at 22:35:46 UTC from IEEE Xplore. Restrictions apply.

IEEE International Conference on Metrology for eXtended Reality, Artificial Intelligence, and Neural Engineering (IEEE MetroXRAINE 2022), 2022. 1

[54] M. J. Page, J. E. McKenzie, P. M. Bossuyt, I. Boutron, T. C. Hoffmann, C. D. Mulrow, L. Shamseer, J. M. Tetzlaff, E. A. Akl, S. E. Brennan, et al. The prisma 2020 statement: an updated guideline for reporting systematic reviews. *bmj*, 372, 2021. 2

[55] A. Patrick, A. Burris, S. Das, and N. Noah. Understanding user perspective in a university setting to improve biometric authentication adoption. In *Proceedings of the 9th Mexican International Conference on Human-Computer Interaction*, pp. 1–10, 2022. 1

[56] P. J. Phillips, A. Martin, C. L. Wilson, and M. Przybocki. An introduction evaluating biometric systems. *Computer*, 33(2):56–63, 2000. 4

[57] V. Reddington, K. Haring, S. Das, and D. Pittman. Development and evaluation of virtual reality classrooms through user-centered design during covid-19. *Proceedings of the SSPXR*, 2022. 1

[58] H. Riyadh, D. Bhardwaj, A. Dabrowski, and K. Krombholz. Usable authentication in virtual reality: Exploring the usability of pins and gestures. In *International Conference on Applied Cryptography and Network Security*, pp. 412–431. Springer, 2024. 5

[59] F. Roesner, T. Kohno, and D. Molnar. Security and privacy for augmented reality systems. *Communications of the ACM*, 57(4):88–96, 2014. 1, 5

[60] M. A. Sasse, S. Brostoff, and D. Weirich. Transforming the 'weakest link'—a human/computer interaction approach to usable and effective security. *BT technology journal*, 19(3):122–131, 2001. 5

[61] F. Schaub, R. Deyhle, and M. Weber. Password entry usability and shoulder surfing susceptibility on different smartphone platforms. In *Proceedings of the 11th international conference on mobile and ubiquitous multimedia*, pp. 1–10, 2012. 4

[62] C. E. Shannon. A mathematical theory of communication. *The Bell system technical journal*, 27(3):379–423, 1948. 4

[63] C. Slocum, Y. Zhang, N. Abu-Ghazaleh, and J. Chen. Going through the motions:{AR/VR} keylogging from user head motions. In *32nd USENIX Security Symposium (USENIX Security 23)*, pp. 159–174, 2023. 1

[64] C. Slocum, Y. Zhang, E. Shayegani, P. Zaree, N. Abu-Ghazaleh, and J. Chen. That doesn't go there: Attacks on shared state in {Multi-User} augmented reality applications. In *33rd USENIX Security Symposium (USENIX Security 24)*, pp. 2761–2778, 2024. 1

[65] S. Stephenson, B. Pal, S. Fan, E. Fernandes, Y. Zhao, and R. Chatterjee. Sok: Authentication in augmented and virtual reality. In *2022 IEEE Symposium on Security and Privacy (SP)*, pp. 267–284. IEEE, 2022. 1, 2

[66] S. Uellenbeck, M. Dürmuth, C. Wolf, and T. Holz. Quantifying the security of graphical passwords: The case of android unlock patterns. In *Proceedings of the 2013 ACM SIGSAC conference on Computer & communications security*, pp. 161–172, 2013. 5

[67] P. Vlachogianni and N. Tselios. Perceived usability evaluation of educational technology using the system usability scale (sus): A systematic review. *Journal of Research on Technology in Education*, 54(3):392–409, 2022. 4

[68] E. Von Zezschwitz, A. De Luca, and H. Hussmann. Survival of the shortest: A retrospective analysis of influencing factors on password composition. In *Human-Computer Interaction–INTERACT 2013: 14th IFIP TC 13 International Conference, Cape Town, South Africa, September 2-6, 2013, Proceedings, Part III 14*, pp. 460–467. Springer, 2013. 4

[69] S. Wiedenbeck, J. Waters, J.-C. Birget, A. Brodskiy, and N. Memon. Passpoints: Design and longitudinal evaluation of a graphical password system. *International journal of human-computer studies*, 63(1-2):102–127, 2005. 5

[70] D. K. Yadav, B. Ionascu, S. V. Krishna Ongole, A. Roy, and N. Memon. Design and analysis of shoulder surfing resistant pin based authentication mechanisms on google glass. In *Financial Cryptography and Data Security: FC 2015 International Workshops, BITCOIN, WAHC, and Wearable*, pp. 281–297. Springer, 2015. 5, 6

[71] Y. Zhang, C. Slocum, J. Chen, and N. Abu-Ghazaleh. It's all in your head (set): Side-channel attacks on {AR/VR} systems. In *32nd USENIX Security Symposium (USENIX Security 23)*, pp. 3979–3996, 2023. 1

[72] Z. Zhang, J. Abbott, S. Das, and L. J. Camp. Building an authentication infrastructure—designing a two factor authentication hardware token with form factor that encourages engagement. *Available at SSRN 4177411*, 2022. 1

A Appendix - Evaluation Criteria Details

Table 2: Symbol Explanations for Evaluation Criteria

Category	Symbol Meaning	Threshold
Effectiveness	− Not explored	N/A
	△ Basic compliance	$<$ 90% Accuracy/Success Rate or $>$ 0.1 error margin (FAR/FRR/EER)
	● Exceptional performance	$\geq$ 90% Accuracy/Success Rate or $\leq$ 0.1 error margin (FAR/FRR/EER)
Security	− Not explored	N/A
	△ Basic compliance	$<$ 20 bits Entropy or $>$ 0.1 error margin for attacks
	● Exceptional performance	$\geq$ 20 bits Entropy or $\leq$ 0.1 error margin for attacks
Usability	− Not explored	N/A
	△ Basic compliance	$>$ 1 minute for times or $<$ 90% Memorability
	● Exceptional performance	$\leq$ 1 minute for times or $\geq$ 90% Memorability
User Perception	− Not explored	N/A
	△ Basic compliance	SUS $\leq$ 68 or $<$ 3.0 on 5-point scale
	● Exceptional performance	SUS $>$ 68 or $\geq$ 3.0 on 5-point scale

Authorized licensed use limited to: COLORADO STATE UNIVERSITY. Downloaded on May 06,2026 at 22:35:46 UTC from IEEE Xplore. Restrictions apply.